

Exposed MySQL Port Investigation

Scenario

You are investigating a university server that may have been unnecessarily exposed to the network.

You have been given the following IP address:

```
10.10.10.50
```

Your first task is to determine which services are exposed.

Step 1 — Discover open ports

Run:

```
nmap 10.10.10.50
```

Example output:

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
3306/tcp	open	mysql

Question

Which port is associated with MySQL?

Answer: 3306/tcp

Step 2 — Identify the service and version

Run:

```
nmap -sV -p 3306 10.10.10.50
```

Example output:

PORT	STATE	SERVICE	VERSION
3306/tcp	open	mysql	MySQL 5.7.42

Now we know:

Port: 3306
Service: MySQL
Version: 5.7.42

Step 3 — Ask the security question

An open port does NOT automatically mean the server is vulnerable.

Ask:

Why might exposing MySQL directly to a network be dangerous?

Possible concerns:

- The database is directly reachable.
- Attackers can identify the database service.
- Authentication can be targeted.
- Weak credentials could lead to unauthorised access.
- An outdated database version may contain known vulnerabilities.
- The database may contain sensitive information.
- The service may have been intended to be accessible only by an application server.

Step 4 — Check whether MySQL is actually reachable

In a controlled lab environment, you could test the service with:

```
nc -vz 10.10.10.50 3306
```

Example:

```
Connection to 10.10.10.50 3306 port [tcp/mysql] succeeded!
```

This tells us that something is accepting TCP connections on port 3306.

It does NOT mean that we have successfully authenticated to MySQL.

Step 5 — Connect the dots

Consider the following attack chain:

```
Internet / Network
|
v
Port Scan
|
v
Port 3306
|
v
MySQL detected
|
v
Version identified
|
v
Attack surface
|
v
Potential authentication
attack
```

Discussion

If you were the defender, would you leave MySQL exposed on `0.0.0.0:3306` ?

What would you do instead?

Possible defensive controls include:

```
Firewall restrictions
+
Network segmentation
+
Private database network
+
Strong authentication
+
Regular patching
+
Monitoring / alerting
```

Challenge

You perform a scan and receive:

PORT	STATE	SERVICE	VERSION
22/tcp	open	ssh	OpenSSH 8.9
80/tcp	open	http	Apache httpd 2.4
3306/tcp	open	mysql	MySQL 5.7.42

You are the security analyst.

Questions

1. Which service has the largest concern if it was never intended to be publicly accessible?
2. What information did the attacker learn?
3. Does an open port prove that the service is vulnerable?
4. What additional information would you want before attempting to exploit anything?
5. What defensive control would you implement first?

Key takeaway

An open port is an open door to a service — but an open door is not automatically an unlocked door.

The security problem comes from understanding **what is exposed, why it is exposed, how it is configured, and whether it should be exposed at all.**